

FEATURE LIST — QUẢN TRỊ & KIỂM TOÁN

Phân hệ Administration & Audit | Profile EMR System

Tổng quan tài liệu

Mục	Nội dung
Tên tài liệu	Feature List — Quản trị & Kiểm toán (Phân quyền & Audit)
Hệ thống	Profile EMR
Phạm vi	Toàn bộ vòng đời quản lý quyền truy cập — từ Onboarding đến Offboarding, bao gồm Authentication, Authorization, các thao tác nghiệp vụ theo nhóm actor, và giám sát liên tục
Số nhóm chức năng	10 nhóm
Tổng số features	104 features

Danh sách chi tiết các tính năng (Feature List)

1. Onboarding — Cấp quyền truy cập

- **Phạm vi:** Toàn bộ quy trình từ khi Supervisor yêu cầu tạo tài khoản cho nhân viên mới đến khi user được activate và đăng nhập lần đầu.
- **Mô tả:** Đảm bảo mỗi nhân viên được cấp đúng quyền, đúng phạm vi (POS), đúng vai trò trước khi truy cập hệ thống EMR.

STT	Tên chức năng	Mô tả
1.1	Yêu cầu Onboarding	Supervisor gửi yêu cầu tạo tài khoản → phải được phê duyệt bởi IT + HR trước khi Sys Admin thực hiện
1.2	Xác minh Danh tính	Xác minh danh tính nhân viên trước khi tạo tài khoản (theo POL-037)
1.3	Tạo Tài khoản User	Tạo tài khoản mới với unique credentials (username/password hoặc liên kết AD/SSO)
1.4	Gán Role chính	Gán role chính theo nhóm: Clinical Provider, Health Administrator, Non-Clinical, System Administrator
1.5	Gán Role phụ	Gán role phụ nếu user kiêm nhiệm nhiều chức năng
1.6	Gán Place of Service (POS)	Gán địa điểm làm việc — giới hạn phạm vi dữ liệu user được truy cập
1.7	Truyền Credential An toàn	Truyền thông tin đăng nhập qua kênh bảo mật (không qua email clear-text)

STT	Tên chức năng	Mô tả
1.8	Kích hoạt Tài khoản	Kích hoạt tài khoản để user có thể đăng nhập lần đầu
1.9	Tài khoản Locum có Ngày hết hạn	Tạo tài khoản Locum với ngày hết hạn tự động — tài khoản tự disable sau expiry
1.10	Tạo Tài khoản hàng loạt	Tạo nhiều tài khoản cùng lúc khi onboarding hàng loạt

2. Authentication — Đăng nhập & Tạo phiên

- **Phạm vi:** Từ khi user nhập credentials đến khi hệ thống tạo session + JWT thành công hoặc từ chối đăng nhập.

- **Mô tả:** Xác thực danh tính user (Authentication only) — chưa kiểm tra quyền thao tác. Đảm bảo chỉ người dùng danh tính mới vào được hệ thống.

STT	Tên chức năng	Mô tả
2.1	Xác thực bằng Username/Password	Xác thực bằng username + password truyền thống
2.2	Xác thực Đa yếu tố (MFA)	Xác thực 2 lớp bằng OTP qua SMS/Email — bật/tắt bởi Clinical Sys Admin
2.3	Kiểm tra Trạng thái Active của tài khoản	Kiểm tra tài khoản còn Active trước khi cho đăng nhập
2.4	Tạo Session với Timeout	Tạo phiên làm việc với timeout 120 phút không thao tác → tự động logout
2.5	Tạo JWT Token	Tạo JSON Web Token chứa UserID, Role, POS, Expiry
2.6	Caching Permission Set	Cache danh sách quyền vào bộ nhớ nhanh (5-10 giây) — giảm tải database
2.7	Ghi Log Đăng nhập thất bại	Ghi audit log mỗi lần đăng nhập thất bại: IP, timestamp, lý do
2.8	Ghi Log Đăng nhập thành công	Ghi audit log mỗi lần đăng nhập thành công: IP, timestamp
2.9	Tự động Đăng xuất khi hết Session	Tự động đăng xuất khi session hết hạn (120 phút không thao tác)
2.10	Tự động vô hiệu hóa tài khoản không hoạt động	Tự động disable tài khoản không đăng nhập > 45 ngày

3. Authorization Engine — Cơ chế kiểm tra quyền

- **Phạm vi:** Cơ chế kỹ thuật kiểm tra quyền trước MỖI thao tác của user sau khi đã đăng nhập thành công.

- **Mô tả:** Hệ thống đọc JWT → kiểm tra Role Action + POS + Context → cho phép hoặc từ chối. Áp dụng cho tất cả 22 actor, không có ngoại lệ.

ST T	Tên chức năng	Mô tả
3.1	Kiểm tra Role Action mỗi Request	Kiểm tra Role Action trước mỗi thao tác - không có ngoại lệ

ST T	Tên chức năng	Mô tả
3.2	Kiểm tra Context POS	Kiểm tra user có được gán POS tương ứng với dữ liệu đang truy cập
3.3	Kiểm soát Truy cập hồ sơ bị Seal	Kiểm tra hồ sơ có bị Seal — nếu Seal, chỉ Break Glass / Sys Admin Unseal mới truy cập được
3.4	Phản hồi Từ chối quyền (HTTP 403)	Trả về lỗi 403 khi user không có quyền — không tiết lộ thông tin nhạy cảm
3.5	Audit Log thao tác kèm Field-Level Diff	Ghi audit log cho mỗi thao tác được phép: Actor, Action, Target, Timestamp, giá trị cũ → mới
3.6	Audit Log Truy cập bị từ chối	Ghi audit log cho mỗi thao tác bị từ chối: Actor, Action attempted, Reason, Timestamp
3.7	Bắt buộc Action yêu cầu Supervisor	Một số action yêu cầu Supervisor ký duyệt (ví dụ: Resident kê đơn) — hệ thống enforce

4. Clinical Provider Actions — Thao tác lâm sàng

- **Phạm vi:** Tất cả thao tác nghiệp vụ mà nhóm Clinical Providers (12 actor) thực hiện trong hệ thống EMR.

- **Mô tả:** Bao gồm kê đơn, tạo encounter, ký lâm sàng, tiêm thuốc, triage, và các quyền đặc biệt (DNR, Break Glass). Mỗi actor có tập quyền khác nhau.

ST T	Tên chức năng	Mô tả
4.1	Có thể kê đơn	Kê đơn thuốc cho bệnh nhân (Doctor, NP, Specialist, Locum)
4.2	Kê đơn ngoài danh mục	Kê đơn thuốc ngoài danh mục hệ thống (Doctor, Specialist only)
4.3	Kê đơn có Supervisor giám sát	Kê đơn dưới sự giám sát — Resident phải có Doctor ký duyệt
4.4	Có thể Cấp/Tiêm thuốc	Tiêm / cấp thuốc trực tiếp cho bệnh nhân (Doctor, Nurse, NP, LPN, Resident, RT)
4.5	Tạo Encounter mới	Tạo lượt khám mới (SOAP / CEF format)
4.6	Ký lâm sàng	Ký xác nhận các xét nghiệm lâm sàng
4.7	Tự động ký Encounter	Tự động ký encounter khi hoàn thành (Doctor, NP, Locum)
4.8	Đặt trạng thái DNR	Đặt trạng thái Do Not Resuscitate (Doctor only)

ST T	Tên chức năng	Mô tả
4.9	Break Glass (Truy cập khẩn cấp)	Truy cập khẩn cấp vào hồ sơ bị Seal hoặc ngoài POS — ghi log đặc biệt (Doctor only)
4.10	Tạo Giấy Giới thiệu (Referral)	Tạo giấy giới thiệu chuyển bệnh nhân đến chuyên khoa khác (Doctor, NP)
4.11	Triage / Đánh giá ban đầu	Đánh giá ban đầu tình trạng bệnh nhân khi đến khám (Nurse, LPN)
4.12	Sửa ghi chú bệnh nhân	Sửa ghi chú bệnh nhân hiển thị khi mở hồ sơ (Doctor, Nurse, NP)
4.13	Thêm vào đơn thuốc thường dùng (Usual Scripts)	Thêm thuốc vào danh sách kê đơn thường dùng (Doctor, NP)
4.14	Quyền truy cập chỉ xem cho sinh viên	Sinh viên chỉ xem Encounter và Medical Record — không tạo, không sửa, không ký

5. Health Administrator Actions — Thao tác hành chính

- **Phạm vi:** Tất cả thao tác nghiệp vụ mà nhóm Health Administrators (4 actor: MOA, Receptionist, Office Manager, Medical Records Staff) thực hiện.

- **Mô tả:** Bao gồm quản lý lịch hẹn, check-in bệnh nhân, quản lý demographics, tài liệu, và cấu hình online booking.

STT	Tên chức năng	Mô tả
5.1	Quản lý lịch hẹn	Đặt / sửa / hủy lịch hẹn cho bệnh nhân (MOA, Receptionist, Office Manager)
5.2	Check-in / Đã đến / Đã khám xong	Đánh dấu trạng thái bệnh nhân: đã đến, đã khám xong (MOA, Receptionist, Office Manager)
5.3	Xem/Sửa thông tin nhân khẩu học bệnh nhân	Xem và sửa thông tin nhân khẩu học bệnh nhân (tất cả Health Admin)
5.4	Có thể đăng ký bệnh nhân	Đăng ký bệnh nhân mới vào hệ thống (MOA, Receptionist, Office Manager)
5.5	Có thể bật đặt lịch online	Bật/tắt tính năng đặt lịch online cho bệnh nhân qua Patient Portal (MOA, Office Manager)
5.6	Quản lý Thư	Tạo và gửi thư (referral letters, appointment reminders) — MOA, Office Manager

STT	Tên chức năng	Mô tả
5.7	Quản lý Tài liệu	Quản lý tài liệu đính kèm hồ sơ bệnh nhân (Office Manager, Medical Records Staff)
5.8	Cho phép sửa nội lục	Tạo/sửa bộ lọc hiển thị danh sách bệnh nhân, lịch hẹn (MOA, Office Manager)
5.9	Quyền truy cập chỉ xem EMR	Xem hồ sơ bệnh án không sửa (Medical Records Staff only)
5.10	Cho phép liên kết sang hồ sơ master Khác	Liên kết hồ sơ bệnh nhân trùng lặp — merge patient records (MOA, Office Manager)

6. Non-Clinical Actions — Thao tác tài chính

- **Phạm vi:** Tất cả thao tác nghiệp vụ mà nhóm Non-Clinical (Medical Billing Coordinator) thực hiện.
- **Mô tả:** Bao gồm tạo hóa đơn, ghi nhận thanh toán, gửi claims bảo hiểm, đối chiếu tài chính, và xuất báo cáo.

STT	Tên chức năng	Mô tả
6.1	Tạo hóa đơn	Tạo hóa đơn cho bệnh nhân sau khám/điều trị
6.2	Ghi nhận thanh toán	Ghi nhận thanh toán từ bệnh nhân (tiền mặt, thẻ, bảo hiểm)
6.3	Gửi Claims hàng loạt	Gửi yêu cầu thanh toán hàng loạt đến cơ quan bảo hiểm y tế
6.4	Đối chiếu Tài chính	Đối chiếu số tiền claim đã gửi với số tiền bảo hiểm thực trả
6.5	Báo cáo Tài chính	Xuất báo cáo tài chính: doanh thu, tỷ lệ reject, outstanding balance
6.6	Đổi chủ hóa đơn	Chuyển hóa đơn từ bác sĩ A sang bác sĩ B
6.7	Cho phép giao dịch sau khi đóng sổ cuối tháng	Cho phép tạo/sửa giao dịch tài chính sau khi đã đóng sổ cuối tháng

7. System Administrator Actions — Thao tác quản trị hệ thống

- **Phạm vi:** Tất cả thao tác mà nhóm System Administrators (3 actor: Clinical Sys Admin, Technical Sys Admin, IntraHealth Power) thực hiện.
- **Mô tả:** Bao gồm quản lý role, cấu hình bảo mật, seal/unseal hồ sơ, import/export dữ liệu, và macro.

STT	Tên chức năng	Mô tả
7.1	Quản lý Roles	Tạo / sửa / xóa role definitions — quyết định role nào có action nào (Clinical Admin, IH Power)

STT	Tên chức năng	Mô tả
7.2	Quản lý People & Places	Quản lý danh sách user và địa điểm (POS) trong hệ thống (tất cả Sys Admin)
7.3	Tùy chỉnh Preferences theo tổ chức	Cấu hình preferences theo clinic: format ngày, ngôn ngữ, module (Clinical Admin, IH Power)
7.4	Tùy chỉnh Preferences toàn hệ thống	Cấu hình toàn hệ thống — bật/tắt module, thiết lập mặc định (Clinical Admin, IH Power)
7.5	Tùy chỉnh Preferences bảo mật	Cấu hình MFA, password policy, session timeout, lockout policy (Clinical Admin, IH Power)
7.6	Thay đổi Role hàng loạt	Thay đổi role hàng loạt cho nhiều user cùng lúc (Clinical Admin, IH Power)
7.7	Duyệt tài khoản domain	Duyệt danh sách tài khoản Windows AD đã liên kết với EMR (tất cả Sys Admin)
7.8	Truy cập công cụ bảo mật (Security Utils)	Truy cập công cụ bảo mật nâng cao: login history, access reports (Clinical Admin, IH Power)
7.9	Seal / Unseal hồ sơ bệnh nhân	Niêm phong / mở niêm phong hồ sơ bệnh nhân nhạy cảm (Clinical Admin, IH Power)
7.10	Chuyển quyền trước Khi xóa User	Chuyển quyền sở hữu dữ liệu trước khi xóa user (Clinical Admin, IH Power)
7.11	Cấu hình Disease Monitors	Cấu hình theo dõi bệnh lý tự động (Clinical Admin, IH Power)
7.12	Import / Export (MERT)	Nhập/xuất dữ liệu hệ thống — migration, backup (tất cả Sys Admin)
7.13	Sửa macro	Tạo/sửa macro tự động hóa nhập liệu (tất cả Sys Admin)
7.14	Sửa macro tích hợp	Sửa macro tích hợp với hệ thống bên ngoài (Technical Admin, IH Power)

8. Patient Portal Actions — Thao tác bệnh nhân

- **Phạm vi:** Tất cả thao tác mà bệnh nhân thực hiện qua Patient Portal — tách biệt hoàn toàn khỏi EMR chính.

- **Mô tả:** Bệnh nhân chỉ xem thông tin và điền form — không truy cập, không sửa hồ sơ bệnh án.

STT	Tên chức năng	Mô tả
8.1	Xem Lịch hẹn	Xem lịch hẹn sắp tới và lịch sử hẹn

STT	Tên chức năng	Mô tả
8.2	Xem Kết quả Xét nghiệm	Xem kết quả xét nghiệm đã được bác sĩ release
8.3	Điền Form Đồng ý (Consent)	Điền form đồng ý trước khi khám/thủ thuật
8.4	Đặt Lịch hẹn Online	Tự đặt lịch hẹn online (chỉ khi clinic bật tính năng)
8.5	Hạn chế Truy cập EMR	KHÔNG được truy cập EMR chính — chỉ xem qua Portal

9. Giám sát & Kiểm toán liên tục

- **Phạm vi:** Toàn bộ hoạt động giám sát, phát hiện bất thường, báo cáo compliance diễn ra liên tục trong suốt vòng đời hệ thống.

- **Mô tả:** SIEM thu thập audit log từ tất cả thao tác → phát hiện bất thường theo thời gian thực → cảnh báo → Sys Admin xử lý → báo cáo compliance.

STT	Tên chức năng	Mô tả
9.1	Thu thập Audit Log thời gian thực	Thu thập audit log từ tất cả thao tác (login, action, denied) theo thời gian thực
9.2	Phát hiện bất thường — Đăng nhập ngoài giờ	Phát hiện đăng nhập ngoài giờ làm việc hoặc từ IP/location bất thường
9.3	Phát hiện bất thường — Từ chối quyền lặp lại	Phát hiện user bị từ chối quyền nhiều lần liên tiếp (brute-force quyền)
9.4	Phát hiện bất thường — Break Glass kích hoạt	Cảnh báo khi Break Glass được kích hoạt — yêu cầu giải trình
9.5	Phát hiện bất thường — Thay đổi Role bất thường	Phát hiện thay đổi role bất thường (privilege escalation)
9.6	Phát hiện bất thường — Truy cập hồ sơ số lượng lớn	Phát hiện user truy cập số lượng lớn hồ sơ bất thường
9.7	Review quyền định kỳ (Hàng năm)	Review quyền định kỳ hàng năm: quyền còn phù hợp? Tài khoản inactive?
9.8	Phát hiện tài khoản không hoạt động (> 45 ngày)	Phát hiện tài khoản không đăng nhập > 45 ngày → đánh dấu để CISO audit
9.9	Báo cáo Compliance	Xuất báo cáo compliance: ai truy cập gì, khi nào, có quyền không
9.10	Tính bất biến của Audit Trail	Audit log không thể bị sửa/xóa bởi bất kỳ ai — đảm bảo tính toàn vẹn

STT	Tên chức năng	Mô tả
9.11	Tích hợp SIEM	Tích hợp với SIEM (Microsoft Sentinel) để phân tích log tập trung và automated alerting

10. Offboarding — Thu hồi quyền

- **Phạm vi:** Toàn bộ quy trình từ khi nhận thông báo nhân viên nghỉ việc đến khi tài khoản bị deactivate hoàn toàn và audit trail được lưu trữ.
- **Mô tả:** Đảm bảo quyền truy cập bị thu hồi kịp thời (trong vòng 24h hoặc ngay lập tức nếu for-cause), không để lại đường truy cập nào.

STT	Tên chức năng	Mô tả
10.1	Thông báo yêu cầu Offboarding	Supervisor thông báo HR + EUS khi nhân viên nghỉ việc / chấm dứt hợp đồng
10.2	Thu hồi quyền truy cập ngay lập tức	Revoke toàn bộ quyền truy cập ngay lập tức (trong vòng 24h, hoặc ngay nếu for-cause)
10.3	Thu hồi ngay role đặc quyền	Đối với Sys Admin / Security-Sensitive Roles: revoke ngay, không chờ notice period
10.4	Xoay vòng (Rotate) Credential chung	Rotate shared credentials, API keys, certificates khi user privileged nghỉ việc
10.5	Vô hiệu hóa tài khoản	Vô hiệu hóa tài khoản — user không đăng nhập được nữa
10.6	Xác minh đã xóa quyền truy cập	Xác minh access đã bị xóa hoàn toàn — sign-off bởi IT Security
10.7	Audit Log vô hiệu hóa	Ghi audit log: Deactivation event, ai thực hiện, khi nào, lý do
10.8	Lưu trữ hồ sơ chấm dứt hợp đồng	Lưu trữ verification records cùng termination documentation
10.9	Chuyển quyền sở hữu dữ liệu	Chuyển quyền sở hữu dữ liệu sang user khác trước khi deactivate
10.10	Tự động hết hạn tài khoản Locum	Tài khoản Locum tự động disable khi đến expiry date